PUBLIC RELEASE / ORDERED IMPLEMENTATION GUIDE

Windows 11 Pro Security Baseline

Action > restart gate > verify > recover > continue

WINDOWS 11 PRO | Version 1.0.0 | Author: Amyashi

Use this edition only	This document contains one ordered path for Windows 11 Pro. Complete each step, its restart decision, and its verification before moving to the next step.
Independent guidance	This independent informational aid is not endorsed by Microsoft or any hardware or security vendor. It is not a live audit, certification, guarantee, incident-response plan, or substitute for professional advice.
License and release notice	Guide materials: CC BY-NC-ND 4.0. Controlled-author terms apply; see LICENSE.md. Version 1.0.0. Source review cut-off: 29 July 2026. Current authoritative documentation takes precedence.

Start here

This is the implementation path. The full control matrix, source traceability, evidence rules, and optional advanced material follow in appendices so they do not interrupt the work.

Mandatory stop	Stop for an organization-managed device, suspected compromise, repeated instability, unavailable recovery, or an unexplained recovery prompt. Do not remove management, clear security keys, or keep hardening during an incident.

Four labels used throughout

[USER]	Run from the normal Windows account; no elevation is expected.
[ADMIN]	Open PowerShell or Windows Terminal with Run as administrator.
[FIRMWARE]	Use only the exact-model OEM UEFI/firmware interface and documentation.
REBOOT GATE	Restart now, verify the one change, run required workflows, and stop on failure.

Result states

STATE	USE IT ONLY WHEN
NOT ASSESSED	No current conclusion has been reached.
OBSERVED	A current value was seen, but effectiveness was not proved.
CONFIGURED	The intended setting was selected, but runtime effect or compatibility was not proved.
PASS	The stated target and test passed with a date and minimal evidence.
HOLD	A prerequisite, ownership question, instability, or safety issue blocks work.
EXCEPTION	A scoped, owned, time-bounded deviation has been accepted and scheduled for review.
N/A	A documented edition, hardware, or use-case reason makes the item unavailable or irrelevant.

Quick implementation path

Follow the step numbers in order. A conditional restart means the full step contains the exact trigger. Do not interpret CONFIGURED as PASS; the verification column in the step must pass.

STEP	DO THIS IN ORDER	RESTART
01	**Confirm edition, authority, and a stable starting point** [USER] | GOV-01, OPS-03, PLT-01	NO
02	**Create the minimal evidence and change record** [USER] | GOV-02, OPS-02	NO
03	**Make and test an independent backup** [USER] | REC-01	NO
04	**Prove encryption recovery, Windows RE, and recovery administration** [USER] then [ADMIN] | REC-02, REC-03, ID-01	NO
05	**Define the tests that every material change must pass** [USER] | OPS-02, PERF-01, PERF-02	NO
06	**Capture the minimum platform inventory** [USER] then [ADMIN] | PLT-01, PLT-02, PLT-03, PLT-04, PLT-05	NO
07	**Install supported Windows, Defender, Store, and application updates** [USER] (elevation if requested) | PLT-01, DEF-01	READ STEP
08	**Service firmware only from the exact-model source** [ADMIN] and [FIRMWARE] | PLT-05, OPS-02	READ STEP
09	**Establish Pro platform trust and inspect Kernel DMA Protection** [ADMIN] and [FIRMWARE] | PLT-02, PLT-03, PLT-04	READ STEP
10	**Separate daily work from administration and keep UAC visible** [USER] then [ADMIN] | ID-01, ID-03, REC-03	NO
11	**Strengthen sign-in and independent account recovery** [USER] | ID-02	NO
12	**Enable and verify BitLocker on the Pro operating-system drive** [ADMIN] | PLT-06, REC-02	READ STEP
13	**Establish a healthy antimalware foundation** [ADMIN] | DEF-01, DEF-02, DEF-03, DEF-04	NO
14	**Turn on reputation protection and keep application defaults** [USER] | APP-01	NO
15	**Keep every Windows Firewall profile enabled** [ADMIN] | NET-01	NO
16	**Keep Pro Remote Desktop and other remote paths off unless required** [USER] then [ADMIN] | NET-02	NO
17	**Remove SMB1 and refuse insecure guest access** [ADMIN] | NET-03	READ STEP
18	**Document DNS and network transitions** [USER] | NET-04	NO
19	**Review and narrow security exceptions before advanced controls** [ADMIN] | OPS-01	NO
20	**Stage the vulnerable-driver blocklist and Memory integrity** [USER] then [ADMIN] | APP-02, PLT-04, PERF-01, PERF-02, OPS-02	READ STEP
21	**Deploy Attack Surface Reduction rules one at a time** [ADMIN] | DEF-05, OPS-02	NO
22	**Stage Controlled Folder Access** [ADMIN] | DEF-06, OPS-02, PERF-02	NO
23	**Stage Microsoft Defender Network Protection** [ADMIN] | DEF-07, OPS-02, PERF-02	NO
24	**Keep Pro logging proportionate; gate optional command-line capture** [ADMIN] | LOG-01, LOG-02, LOG-03	NO
25	**Run final acceptance and schedule reassessment** [USER] | OPS-01, OPS-02, OPS-03, OPS-04, PERF-01, PERF-02	NO

Step 01 - Confirm edition, authority, and a stable starting point

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE A. Safety and recovery **CONTROLS** GOV-01, OPS-03, PLT-01	**PRIORITY** P0	**RUN AS** [USER]	**ACTION TYPE** READ-ONLY / DECISION	**SOURCES** [1], [2], [3], [6]

Goal Prove that this is the correct edition guide, the device is personally controlled, and baseline work is safe to begin.

BEFORE YOU START

- Use a personally owned, unmanaged Windows 11 device.
- Stop if active compromise, repeated crashes, recovery prompts, data loss, or unexplained control changes are present.

DO THIS IN ORDER

1. Open Settings > System > About and confirm the edition named on this guide.

2. Open Settings > Accounts > Access work or school. Stop for any unknown organization, tenant, or management connection.

3. Run the commands only for on-screen review. Do not save or publish raw dsregcmd output.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
Get-ComputerInfo |
Select-Object WindowsProductName,WindowsVersion,OsBuildNumber
dsregcmd.exe /status
perfmon.exe /rel
```

RESTART NOW?
NO. This step makes no configuration change.

VERIFY BEFORE CONTINUING

1. The edition matches this guide.

2. No employer, school, client, domain, or mobile-device-management authority controls the device.

3. Reliability Monitor shows no unresolved pattern that should pause hardening.

PASS LOOKS LIKE
Edition and ownership are confirmed; no incident or instability stop condition is present.

IF IT DOES NOT PASS
STOP. Use the correct edition guide, contact the authorized administrator, or follow an incident/repair path before continuing.

ROLLBACK / RECOVERY
None. This is a gate, not a change.

RECORD ONLY
Record only edition, Windows release/build, date, and PASS or HOLD. Do not retain tenant, account, or device identifiers.

Step 02 - Create the minimal evidence and change record

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE A. Safety and recovery **CONTROLS** GOV-02, OPS-02	**PRIORITY** P0	**RUN AS** [USER]	**ACTION TYPE** DECISION / RECORD	**SOURCES** [1], [2], [4]

Goal Keep enough information to repeat and reverse a decision without collecting secrets or personal data.

BEFORE YOU START

- Step 01 passed.
- Choose an access-controlled location outside any public repository for restricted evidence.

DO THIS IN ORDER

1. Create one row per step with: step/control ID, date, result, method, sanitized result, prior-to-new state, restart completed, owner, and next review.

2. Define a deletion/review date for raw logs or screenshots.

3. Never record recovery keys, passwords, tokens, serials, account names, public addresses, user paths, raw dumps, or unredacted logs.

COMMANDS: None. Use the supported interface named above.

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. A blank record exists.

2. Restricted evidence has a separate protected location and retention rule.

PASS LOOKS LIKE
The record can support a decision without exposing secret or unnecessary personal information.

IF IT DOES NOT PASS
HOLD. Move or sanitize existing evidence before continuing.

ROLLBACK / RECOVERY
Delete the empty record if the assessment is abandoned; do not delete material under an investigation or legal hold.

RECORD ONLY
Record the storage location by a non-sensitive label, not a path, account, or URL.

Step 03 - Make and test an independent backup

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE A. Safety and recovery **CONTROLS** REC-01	**PRIORITY** P0	**RUN AS** [USER]	**ACTION TYPE** ACTIVE RESTORE TEST	**SOURCES** [1], [2], [5]

Goal Prevent a security change, device failure, or ransomware event from leaving the only copy unusable.

BEFORE YOU START

- Steps 01 and 02 passed.
- Identify the files and settings whose loss would matter.

DO THIS IN ORDER

1. Create or update a backup that is not continuously writable by the daily Windows session.

2. Disconnect or otherwise isolate that copy when the backup completes.

3. Restore one harmless representative file to a different location, open it, then remove the temporary restored copy.

COMMANDS: None. Use the supported interface named above.

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. The backup date and scope cover the identified critical data.

2. The representative restore succeeds from the independent copy.

PASS LOOKS LIKE
A current independent copy exists and a representative restore works.

IF IT DOES NOT PASS
HOLD all firmware, encryption, account, and platform changes until a restore succeeds.

ROLLBACK / RECOVERY
Correct the backup design or destination; do not overwrite the only known-good copy while troubleshooting.

RECORD ONLY
Record backup scope, date, and restore PASS only. Do not list filenames or storage credentials.

Independent informational aid | CC BY-NC-ND 4.0 controlled-author terms in LICENSE.md | Do not record secrets

Step 04 - Prove encryption recovery, Windows RE, and recovery administration

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE A. Safety and recovery **CONTROLS** REC-02, REC-03, ID-01	**PRIORITY** P0	**RUN AS** [USER] then [ADMIN]	**ACTION TYPE** READ-ONLY / ACTIVE SIGN-IN TEST	**SOURCES** [2], [7], [18], [30], [31], [32], [48]

Goal Make sure a later boot, encryption, or account change cannot lock the owner out without a tested recovery path.

BEFORE YOU START

- Step 03 passed.
- Have a second trusted device or independent location available when the drive is already encrypted.

DO THIS IN ORDER

1. Review the edition-specific encryption page named in Step 12 and record only On, Off, or unavailable.

2. If encryption is already on, prove that the matching recovery method can be reached independently. Never copy the secret into the workbook.

3. Confirm Windows Recovery Environment is enabled.

4. Create or retain a separate recovery administrator through Settings > Accounts > Other users, then sign in once and cancel a harmless elevation prompt.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
manage-bde.exe -status C:
reagentc.exe /info
$admins = Get-LocalGroup -SID 'S-1-5-32-544'
Get-LocalGroupMember -Group $admins
```

RESTART NOW?
NO. A sign-out/sign-in is sufficient for the administrator test.

VERIFY BEFORE CONTINUING

1. Encryption state is understood.

2. When encryption is active, the matching recovery method is independently accessible.

3. Windows RE reports Enabled and the separate administrator can sign in and elevate.

PASS LOOKS LIKE
All recovery paths work without recording a recovery secret.

IF IT DOES NOT PASS
HOLD. Do not change firmware, Secure Boot, TPM, encryption, Memory integrity, or account roles.

ROLLBACK / RECOVERY
Restore the prior account role from the already working administrator if an account change fails.

RECORD ONLY
Record encryption state, Windows RE Enabled, and recovery-admin test PASS. Do not record protector IDs or key values.

Step 05 - Define the tests that every material change must pass

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE A. Safety and recovery **CONTROLS** OPS-02, PERF-01, PERF-02	**PRIORITY** P0	**RUN AS** [USER]	**ACTION TYPE** DECISION / RECORD	**SOURCES** [1], [2]

Goal Turn compatibility and performance into repeatable acceptance checks instead of guesswork.

BEFORE YOU START

- Steps 01 through 04 passed.
- Know which applications, games, peripherals, networks, and recovery functions are actually required.

DO THIS IN ORDER

1. List required sign-in/elevation, update, browser/download, save/open/export/sync, print, voice/video, game/anti-cheat, VPN/network-switch, peripheral, sleep/resume, and recovery workflows.

2. Define only meaningful performance or reliability limits for this device.

3. Adopt the rule: one material change, focused verification, required-workflow test, observation, then the next change.

COMMANDS: None. Use the supported interface named above.

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. Each required workflow has a short repeatable test.

2. The owner knows which latest change to reverse if a test fails.

PASS LOOKS LIKE
A reusable acceptance list and latest-change rollback rule exist.

IF IT DOES NOT PASS
HOLD compatibility-sensitive controls until the tests are defined.

ROLLBACK / RECOVERY
Remove a test only when the underlying required workflow is intentionally retired.

RECORD ONLY
Record test names and limits, not private content or application data.

Step 06 - Capture the minimum platform inventory

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE B. Platform trust **CONTROLS** PLT-01, PLT-02, PLT-03, PLT-04, PLT-05	**PRIORITY** P1	**RUN AS** [USER] then [ADMIN]	**ACTION TYPE** READ-ONLY	**SOURCES** [6], [8], [21], [22]

Goal Identify the exact Windows, firmware, Secure Boot, TPM, and virtualization state before changing any of them.

BEFORE YOU START

- The safety and recovery phase passed.
- Open an elevated PowerShell window only for the commands marked [ADMIN].

DO THIS IN ORDER

1. Run the commands and review them on screen.
2. Open msinfo32 and inspect BIOS Mode and Secure Boot State.
3. Open Task Manager > Performance > CPU and inspect Virtualization.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
Get-CimInstance Win32_OperatingSystem |
Select-Object Caption,Version,BuildNumber,LastBootUpTime
Get-CimInstance Win32_ComputerSystem |
Select-Object Manufacturer,Model
Get-CimInstance Win32_BIOS |
Select-Object SMBIOSBIOSVersion,ReleaseDate
Confirm-SecureBootUEFI
Get-Tpm | Select-Object TpmPresent,TpmReady,TpmEnabled,`
TpmActivated,LockedOut
```

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. Exact model, Windows build, firmware version/date, BIOS mode, Secure Boot, TPM, and CPU virtualization are known.
2. A failed or unsupported query is recorded as UNKNOWN or HOLD, never PASS.

PASS LOOKS LIKE
The minimum platform state is known without exporting identifiers.

IF IT DOES NOT PASS
HOLD the affected platform change and use the exact vendor documentation to resolve an unknown state.

ROLLBACK / RECOVERY
None. Inventory is read-only.

RECORD ONLY
Record only the model family, firmware version/date, and summarized security states. Omit serials and raw exports.

Step 07 - Install supported Windows, Defender, Store, and application updates

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE B. Platform trust **CONTROLS** PLT-01, DEF-01	**PRIORITY** P1	**RUN AS** [USER] (elevation if requested)	**ACTION TYPE** CONFIGURATION CHANGE	**SOURCES** [6], [11]

Goal Close known vulnerabilities before spending time tuning dependent controls.

BEFORE YOU START

- The recovery gate passed.
- Honor any Microsoft or vendor safeguard hold for the exact device.

DO THIS IN ORDER

1. Open Windows Update and install normal security and servicing updates. Do not install a preview solely for this baseline.

2. Update Microsoft Store applications and other required applications from their supported vendor channels.

3. Update Defender security intelligence.

4. Restart when Windows or an installer requests it, then return immediately to the verification below.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
Start-Process 'ms-settings:windowsupdate'
Update-MpSignature
```

RESTART NOW?
YES when requested. Do not make another change before the post-restart checks pass.

VERIFY BEFORE CONTINUING

1. Sign in without a recovery prompt or new failure.

2. Open Windows Update again; no security update or pending restart remains.

3. Run the required workflows defined in Step 05.

VERIFICATION COMMANDS

```
winver.exe
(Get-MpComputerStatus).AntivirusSignatureLastUpdated
```

PASS LOOKS LIKE
Windows is supported and current, Defender intelligence is current, and required workflows pass.

IF IT DOES NOT PASS
HOLD. Use Windows release-health or the exact application/vendor support path; do not bypass a documented safeguard hold.

ROLLBACK / RECOVERY
Uninstall only the latest documented update when official guidance and a reproducible failure justify it.

RECORD ONLY
Record Windows release/build, update completion date, restart complete, and sanitized test result.

Step 08 - Service firmware only from the exact-model source

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE B. Platform trust **CONTROLS** PLT-05, OPS-02	**PRIORITY** P1	**RUN AS** [ADMIN] and [FIRMWARE]	**ACTION TYPE** CONFIGURATION CHANGE	**SOURCES** [2], [6], [48]

Goal Apply applicable firmware security fixes without cross-flashing, skipping prerequisites, or losing known-good settings.

BEFORE YOU START

- Steps 03 through 06 passed.
- Stable power is available and the exact system or motherboard model and revision are known.

DO THIS IN ORDER

1. Compare the installed version only with the exact OEM/system or motherboard support page.
2. Read release notes, prerequisites, recovery instructions, and any required component order.
3. Record current deliberate boot, security, storage, fan, memory, and tuning settings.
4. Apply at most one exact-model firmware package through the documented OEM method.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
Get-CimInstance Win32_ComputerSystem |
Select-Object Manufacturer,Model
Get-CimInstance Win32_BaseBoard |
Select-Object Manufacturer,Product,Version
Get-CimInstance Win32_BIOS |
Select-Object SMBIOSBIOSVersion,ReleaseDate
```

RESTART NOW?
YES after an applied firmware package. Treat this as a REBOOT GATE.

VERIFY BEFORE CONTINUING

1. Re-run firmware inventory, Secure Boot, TPM, encryption, and any virtualization state affected by the update.
2. Run the Step 05 workflow and performance checks.

VERIFICATION COMMANDS

```
Confirm-SecureBootUEFI
Get-Tpm | Select-Object TpmPresent,TpmReady,TpmEnabled,`
TpmActivated,LockedOut
manage-bde.exe -status C:
```

PASS LOOKS LIKE
The exact package applies, the update succeeds, security settings remain correct, and required workflows pass.

IF IT DOES NOT PASS
HOLD for an unclear model, revision, prerequisite, power condition, recovery path, or post-update failure.

ROLLBACK / RECOVERY
Restore only the recorded prior firmware setting that changed. Never clear TPM, CMOS, or Secure Boot keys as routine rollback.

RECORD ONLY
Record exact model family, old/new firmware version, source page date, restart, and sanitized verification result.

Step 09 - Establish Pro platform trust and inspect Kernel DMA Protection

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE B. Platform trust **CONTROLS** PLT-02, PLT-03, PLT-04	**PRIORITY** P0/P2	**RUN AS** [ADMIN] and [FIRMWARE]	**ACTION TYPE** CONDITIONAL CONFIGURATION CHANGE / REBOOT GATE	**SOURCES** [8], [21], [22]

Goal Verify Secure Boot and TPM, then separately evaluate CPU virtualization, IOMMU, and Kernel DMA Protection on supported Pro hardware.

BEFORE YOU START

- Steps 03 through 06 passed.
- Use only the exact-model firmware manual and change one setting at a time.

DO THIS IN ORDER

1. Require UEFI mode and Secure Boot enabled. If Windows starts in Legacy/CSM mode, stop for an exact supported migration plan.

2. Require TPM present, ready, enabled, activated, and not locked out. Clearing or reprovisioning the TPM is outside this guide.

3. Open msinfo32 and inspect Kernel DMA Protection separately from CPU virtualization.

4. When Kernel DMA Protection is Off because firmware virtualization/IOMMU is disabled, use exact-model instructions and change only the required CPU virtualization or VT-d/AMD IOMMU setting.

5. After any firmware change, complete the REBOOT GATE and re-check every affected state.

COMMANDS: None. Use the supported interface named above.

RESTART NOW?
YES after any firmware setting change.

VERIFY BEFORE CONTINUING

1. Confirm-SecureBootUEFI returns True and TPM fields pass.

2. msinfo32 reports Kernel DMA Protection On when the Pro device and hardware support it.

3. Task Manager reports Virtualization Enabled when intentionally enabled.

4. No recovery prompt, crash, device failure, or workflow regression follows the change.

VERIFICATION COMMANDS

```
Confirm-SecureBootUEFI
Get-Tpm | Select-Object TpmPresent,TpmReady,TpmEnabled,`
TpmActivated,LockedOut
```

PASS LOOKS LIKE
Secure Boot and TPM pass; supported Pro hardware reports Kernel DMA Protection On; required workflows pass.

IF IT DOES NOT PASS
HOLD. Do not clear TPM or Secure Boot keys, convert boot mode generically, or stack another firmware change.

ROLLBACK / RECOVERY
Restore only the latest recorded firmware setting through the exact-model UI, reboot, and re-verify.

RECORD ONLY
Record summarized runtime states and the one prior-to-new firmware setting. Do not record keys or identifiers.

Step 10 - Separate daily work from administration and keep UAC visible

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE C. Identity and least privilege **CONTROLS** ID-01, ID-03, REC-03	**PRIORITY** P1	**RUN AS** [USER] then [ADMIN]	**ACTION TYPE** CONFIGURATION CHANGE / ACTIVE SIGN-IN TEST	**SOURCES** [2], [18], [19]

Goal Reduce routine administrative exposure without creating a lockout.

BEFORE YOU START

- The separate recovery administrator from Step 04 works.
- Do not demote or remove the last tested administrator.

DO THIS IN ORDER

1. In Settings > Accounts > Other users, confirm the recovery administrator first.
2. Change the routine account to Standard when practical.
3. Open Change User Account Control settings and keep the Windows default level or higher.
4. From the daily account, start a harmless Run as administrator action and cancel the visible secure-desktop prompt.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
$admins = Get-LocalGroup -SID 'S-1-5-32-544'
Get-LocalGroupMember -Group $admins
$uacPath = 'HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion'
$uacPath = Join-Path $uacPath 'Policies\System'
$uac = Get-ItemProperty $uacPath
$uac | Select-Object EnableLUA,ConsentPromptBehaviorAdmin,`
PromptOnSecureDesktop
```

RESTART NOW?
NO. Sign out and sign back in after changing an account type.

VERIFY BEFORE CONTINUING

1. Routine work uses a Standard account or has a documented exception.
2. A separate administrator works and UAC produces a deliberate visible prompt.

PASS LOOKS LIKE
Daily use is separated from administration and recovery administration remains tested.

IF IT DOES NOT PASS
HOLD. Sign in with the recovery administrator and restore the prior account type before other changes.

ROLLBACK / RECOVERY
Restore only the affected account type through Settings. Do not weaken UAC to repair an unrelated application.

RECORD ONLY
Record account roles, not account names. Record UAC as default-or-higher and the prompt test PASS.

Step 11 - Strengthen sign-in and independent account recovery

PHASE C. Identity and least privilege CONTROLS ID-02	PRIORITY P1	RUN AS [USER]	ACTION TYPE CONFIGURATION CHANGE / ACTIVE RECOVERY TEST	SOURCES [1], [23]

Goal Reduce account takeover risk without replacing one working factor before its successor is proved.

BEFORE YOU START

- The owner can reach each important account from a trusted device.
- An offline location is available for recovery codes.

DO THIS IN ORDER

1. Configure Windows Hello or a passkey where offered.
2. Use phishing-resistant multi-factor authentication for important online accounts where supported.
3. Keep two independent recovery methods and protect recovery codes offline.
4. Test the new sign-in and recovery route before removing an old factor.

COMMANDS: None. Use the supported interface named above.

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. The new sign-in works.
2. Two independent recovery routes are available and at least one was tested without revealing a secret.

PASS LOOKS LIKE
Strong sign-in and independent recovery are configured and tested.

IF IT DOES NOT PASS
HOLD. Keep the old working factor until the replacement and recovery path pass.

ROLLBACK / RECOVERY
Re-add or retain the prior factor through the account provider's official security page.

RECORD ONLY
Record factor types and PASS only. Never record codes, secrets, phone numbers, or account addresses.

Step 12 - Enable and verify BitLocker on the Pro operating-system drive

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE B. Platform trust **CONTROLS** PLT-06, REC-02	**PRIORITY** P1	**RUN AS** [ADMIN]	**ACTION TYPE** CONFIGURATION CHANGE / SYSTEM-CHECK REBOOT	**SOURCES** [7], [32], [39], [40], [41]

Goal Protect the Pro operating-system drive through the supported BitLocker wizard and proved recovery.

BEFORE YOU START

- Backup, Windows RE, recovery administration, and acceptance tests passed.
- HOLD for an unexplained suspended, encrypting, decrypting, or waiting-for-activation state.
- Do not change TPM, firmware, Secure Boot, partitions, or boot mode in the same change window.

DO THIS IN ORDER

1. Open Start, type Manage BitLocker, and open BitLocker Drive Encryption.
2. For C:, select Turn on BitLocker and use the normal TPM-based option offered by Windows.
3. Save the recovery key to a trusted location separate from the PC and prove the matching record without copying the 48-digit value.
4. For an existing installation, choose Encrypt entire drive; use the new encryption mode for the internal Windows 11 drive.
5. Keep Run BitLocker system check enabled and restart when the wizard requests it.
6. Keep reliable power connected while encryption completes.

COMMANDS: None. Use the supported interface named above.

RESTART NOW?
YES when the wizard requests the BitLocker system check. Complete the REBOOT GATE.

VERIFY BEFORE CONTINUING

1. VolumeStatus is FullyEncrypted, ProtectionStatus is On, and EncryptionPercentage is 100.
2. TPM and recovery-password protector types exist; do not display or record the recovery password.
3. The independent recovery record is retrievable and Windows RE remains enabled.

VERIFICATION COMMANDS

```
$b = Get-BitLockerVolume -MountPoint 'C:'
$b | Select-Object MountPoint,VolumeStatus,ProtectionStatus,`
EncryptionPercentage,EncryptionMethod,LockStatus
$b.KeyProtector | Select-Object KeyProtectorType,KeyProtectorId
reagentc.exe /info
```

PASS LOOKS LIKE
BitLocker is fully encrypted, protected, recoverable, and stable after the system-check restart.

IF IT DOES NOT PASS
HOLD. Resolve the wizard's exact prerequisite or an unexplained protection state; do not force TPM or boot changes.

ROLLBACK / RECOVERY
If a stable device must reverse the policy, use Manage BitLocker > Turn off BitLocker. Decryption is not routine troubleshooting and must not begin from a failing drive or recovery loop.

RECORD ONLY
Record status fields, protector types, restart, and recovery-method PASS. Never record the key or protector identifier.

Step 13 - Establish a healthy antimalware foundation

PHASE D. Defender and application protection **CONTROLS** DEF-01, DEF-02, DEF-03, DEF-04	**PRIORITY** P1	**RUN AS** [ADMIN]	**ACTION TYPE** CONFIGURATION CHANGE / ACTIVE SCAN	**SOURCES** [11], [24], [25], [26], [33]

Goal Make the intended antimalware provider active and current before enabling dependent protections.

BEFORE YOU START

- Windows and application updates passed.
- If another antivirus intentionally owns protection, assess that provider instead of forcing two active providers.

DO THIS IN ORDER

1. In Windows Security, enable real-time, behavior, IOAV, tamper, and cloud-delivered protection where Defender is the active provider.
2. Choose sample-submission behavior intentionally based on privacy needs.
3. Enable PUA protection in Block mode.
4. Update signatures and run a Quick scan.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
Update-MpSignature
Set-MpPreference -PUAProtection Enabled
Start-MpScan -ScanType QuickScan
```

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. Defender is active, runtime protections are true, tamper protection is on, signatures are current, and PUA is Enabled.
2. The Quick scan completes without an unresolved detection.

VERIFICATION COMMANDS

```
$s = Get-MpComputerStatus
$s | Format-List AMRunningMode,AMServiceEnabled,`
AntivirusEnabled,RealTimeProtectionEnabled
$s | Format-List BehaviorMonitorEnabled,IoavProtectionEnabled,`
IsTamperProtected
$s | Format-List AntivirusSignatureLastUpdated,QuickScanEndTime
Get-MpPreference |
Format-List MAPSReporting,SubmitSamplesConsent,PUAProtection
```

PASS LOOKS LIKE
The intended provider is healthy and all required Defender foundation values pass.

IF IT DOES NOT PASS
HOLD advanced Defender steps. Resolve provider ownership, updates, detections, or policy control first.

ROLLBACK / RECOVERY
Restore only the recorded PUA state if a documented compatibility reason requires it; never defeat tamper protection.

RECORD ONLY
Record provider name, summarized states, signature date, and Quick-scan completion. Do not attach detection details publicly.

Step 14 - Turn on reputation protection and keep application defaults

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE D. Defender and application protection **CONTROLS** APP-01	**PRIORITY** P1	**RUN AS** [USER]	**ACTION TYPE** CONFIGURATION CHANGE / ACTIVE APP TEST	**SOURCES** [27]

Goal Block known risky sites, downloads, and applications while preserving supported required software.

BEFORE YOU START

- The antimalware foundation passed.
- Know which browsers and applications are required.

DO THIS IN ORDER

1. Open Windows Security > App & browser control > Reputation-based protection.

2. Enable applicable SmartScreen, phishing, and unwanted-app checks.

3. Keep Exploit Protection at Microsoft system defaults unless one exact tested application requires an override.

4. Treat Smart App Control as conditional: use only the state the current Windows Security UI supports; it has no per-app allow rule.

5. Confirm every installed browser is supported, current, and using its built-in malicious-site and dangerous-download protection.

COMMANDS: None. Use the supported interface named above.

RESTART NOW?
NO, unless Windows explicitly requests one.

VERIFY BEFORE CONTINUING

1. Applicable reputation layers are enabled.

2. Required applications and browsers launch, update, download, and authenticate normally.

PASS LOOKS LIKE
Applicable reputation protections are on and required software passes.

IF IT DOES NOT PASS
HOLD an unverified blocked application. Verify publisher, source, hash, and need before any exception.

ROLLBACK / RECOVERY
Undo only the exact application override that caused the failure; do not disable global reputation protection.

RECORD ONLY
Record protection states and application-test PASS. Do not record browsing history or downloaded filenames.

Step 15 - Keep every Windows Firewall profile enabled

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE E. Network and remote exposure **CONTROLS** NET-01	**PRIORITY** P1	**RUN AS** [ADMIN]	**ACTION TYPE** CONFIGURATION CHANGE / ACTIVE NETWORK TEST	**SOURCES** [16], [37]

Goal Preserve host firewall protection on trusted and untrusted networks without relying on blanket exceptions.

BEFORE YOU START

- Confirm Windows Firewall is the intended active host firewall.
- Have the Step 05 network, VPN, sharing, printing, game, and communications tests ready.

DO THIS IN ORDER

1. Inspect the effective profile state.
2. If any profile is disabled and Windows Firewall is the intended provider, enable all three profiles.
3. Do not change the global outbound default in this baseline.
4. Run the required network workflows.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
$fw = Get-NetFirewallProfile -PolicyStore ActiveStore
$fw | Select-Object Name,Enabled,DefaultInboundAction,`
DefaultOutboundAction
Set-NetFirewallProfile -Profile Domain,Private,Public `
-Enabled True
```

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. Domain, Private, and Public profiles report Enabled.
2. Required workflows pass and any custom inbound rule is narrow in program, service, port, profile, and remote scope.

VERIFICATION COMMANDS

```
Get-NetFirewallProfile -PolicyStore ActiveStore |
Select-Object Name,Enabled
```

PASS LOOKS LIKE
All firewall profiles are enabled and required network workflows pass.

IF IT DOES NOT PASS
HOLD the affected application. Keep the firewall on and repair only a specific justified rule.

ROLLBACK / RECOVERY
Disable or remove only the latest specific rule created during troubleshooting. Never disable all profiles.

RECORD ONLY
Record profile Enabled states and workflow PASS. Do not save addresses or full rule exports publicly.

Step 16 - Keep Pro Remote Desktop and other remote paths off unless required

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE E. Network and remote exposure **CONTROLS** NET-02	**PRIORITY** P1	**RUN AS** [USER] then [ADMIN]	**ACTION TYPE** READ-ONLY / CONDITIONAL CONFIGURATION CHANGE	**SOURCES** [16], [28], [43]

Goal Minimize incoming remote access and, when RDP hosting is required, keep NLA and narrow trusted-network scope.

BEFORE YOU START

- Document the remote-access need before enabling a host.
- Never expose TCP 3389 directly to the Internet; use a VPN for access from outside the trusted network.

DO THIS IN ORDER

1. Open Settings > System > Remote Desktop. Leave it Off when not required.

2. If required, use Appendix D: keep Network Level Authentication on, authorize only intended accounts, and restrict inbound rules to Private/LocalSubnet or narrower.

3. Turn off Remote Assistance when unused; use Quick Assist only for an initiated, independently verified session.

4. Inspect Remote Registry, WinRM, RDP state, and listeners.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
$rdpPath = 'HKLM:\SYSTEM\CurrentControlSet\Control'
$rdpPath = Join-Path $rdpPath 'Terminal Server'
$rdp = Get-ItemProperty $rdpPath
$rdp.fDenyTSConnections
Get-Service RemoteRegistry,WinRM -ErrorAction SilentlyContinue |
Select-Object Name,Status,StartType
Get-NetTCPConnection -LocalPort 3389 -State Listen `
-ErrorAction SilentlyContinue
```

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. If unused, fDenyTSConnections is 1 and no TCP 3389 listener exists.

2. If required, NLA is enabled, intended accounts alone can connect, and firewall scope is trusted-network-only.

3. Every other retained remote path is understood and reviewed.

PASS LOOKS LIKE
Unused remote paths are off; any required RDP host is strongly authenticated and narrowly scoped.

IF IT DOES NOT PASS
Turn RDP Off and HOLD after an unknown session, listener, account, rule, or direct Internet exposure.

ROLLBACK / RECOVERY
Settings > System > Remote Desktop > Off, then confirm fDenyTSConnections is 1 and no listener remains.

RECORD ONLY
Record Off or required/scoped PASS only. Do not record account names, addresses, or session details.

Step 17 - Remove SMB1 and refuse insecure guest access

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE E. Network and remote exposure **CONTROLS** NET-03	**PRIORITY** P1	**RUN AS** [ADMIN]	**ACTION TYPE** CONDITIONAL CONFIGURATION CHANGE	**SOURCES** [17], [38], [47]

Goal Remove legacy file-sharing behavior without silently breaking a required authenticated share.

BEFORE YOU START

- Inventory every required network share and its supported authentication method.
- Do not expose SMB directly to the public Internet.

DO THIS IN ORDER

1. Query SMB1. Run the disable command only when State is Enabled.

2. Inspect insecure guest-logon state.

3. After required authenticated shares are proved, set insecure guest logons to false if they are true.

4. Restart only if the feature change or Windows requests it, then test each authenticated share.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
Get-WindowsOptionalFeature -Online -FeatureName SMB1Protocol |
Select-Object FeatureName,State
Disable-WindowsOptionalFeature -Online `
-FeatureName SMB1Protocol -NoRestart
Get-SmbClientConfiguration |
Select-Object EnableInsecureGuestLogons
Set-SmbClientConfiguration `
-EnableInsecureGuestLogons $false -Force
```

RESTART NOW?
YES after disabling SMB1 or when Windows requests it. Treat it as a REBOOT GATE.

VERIFY BEFORE CONTINUING

1. SMB1 reports Disabled.

2. EnableInsecureGuestLogons reports False.

3. Every required share authenticates and works after the restart.

VERIFICATION COMMANDS

```
Get-WindowsOptionalFeature -Online -FeatureName SMB1Protocol |
Select-Object FeatureName,State
Get-SmbClientConfiguration |
Select-Object EnableInsecureGuestLogons
```

PASS LOOKS LIKE
Legacy SMB1 and insecure guest access are absent; required authenticated shares work.

IF IT DOES NOT PASS
HOLD and update, replace, or isolate a legacy dependency. Do not silently re-enable SMB1.

ROLLBACK / RECOVERY
Restore only a documented, time-bounded compatibility state after accepting the risk; replacement is the preferred resolution.

RECORD ONLY
Record feature and guest states plus sanitized share-test PASS. Do not record server names or addresses.

Step 18 - Document DNS and network transitions

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE E. Network and remote exposure **CONTROLS** NET-04	**PRIORITY** P2	**RUN AS** [USER]	**ACTION TYPE** READ-ONLY / CONDITIONAL CHANGE	**SOURCES** [29]

Goal Keep name resolution understandable and reliable across browser, Windows, router, VPN, Ethernet, and Wi-Fi layers.

BEFORE YOU START

- Know whether a VPN, filtered resolver, router policy, or browser secure-DNS setting is intended.
- Do not publish the command output because it can include network identifiers.

DO THIS IN ORDER

1. Inspect current resolver state on screen.
2. Choose one documented resolver model; filtered DNS is optional defense in depth, not a replacement for endpoint protection.
3. If changing a layer, change only one and test browsing, updates, captive portal, VPN connect/disconnect, and Ethernet/Wi-Fi failover.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
Get-DnsClientServerAddress -AddressFamily IPv4,IPv6
Resolve-DnsName example.com -DnsOnly
```

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. Normal resolution and all required transitions work.
2. Browser, Windows, router, and VPN resolver choices match the documented design.

PASS LOOKS LIKE
The selected resolver design is intentional and required transitions pass.

IF IT DOES NOT PASS
Restore the latest resolver layer and HOLD after repeated stable-link resolution failure or unclear policy ownership.

ROLLBACK / RECOVERY
Restore only the latest recorded browser, adapter, VPN, or router resolver setting.

RECORD ONLY
Record the design label and tests, not resolver addresses, adapter names, or network captures.

Step 19 - Review and narrow security exceptions before advanced controls

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE F. Staged hardening **CONTROLS** OPS-01	**PRIORITY** P1	**RUN AS** [ADMIN]	**ACTION TYPE** READ-ONLY / CONDITIONAL CHANGE	**SOURCES** [1], [2]

Goal Prevent broad exclusions and allowances from silently defeating the controls being added next.

BEFORE YOU START

- The intended antimalware and firewall providers are known.
- Review raw paths only on the local device.

DO THIS IN ORDER

1. Inspect Defender exclusions and CFA allowed applications locally.
2. Review firewall rules, browser overrides, remote paths, and other security exceptions.
3. Investigate an unknown item before deleting it.
4. For every retained item, record exact scope, owner, reason, test, approval date, and next review.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
$p = Get-MpPreference
$p | Select-Object ExclusionPath,ExclusionProcess,`
ExclusionExtension
$p | Select-Object ControlledFolderAccessAllowedApplications
```

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. No unexplained broad or permanent exception remains.
2. Each retained exception is exact, owned, tested, and scheduled for review.

PASS LOOKS LIKE
Every retained exception is narrow and justified.

IF IT DOES NOT PASS
HOLD the dependent advanced control while an exception's owner, need, or effect is unknown.

ROLLBACK / RECOVERY
Re-add only the exact item removed most recently when evidence proves it was required.

RECORD ONLY
Record counts and decision labels only. Never paste exclusion paths into public evidence.

Step 20 - Stage the vulnerable-driver blocklist and Memory integrity

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE F. Staged hardening **CONTROLS** APP-02, PLT-04, PERF-01, PERF-02, OPS-02	**PRIORITY** P2	**RUN AS** [USER] then [ADMIN]	**ACTION TYPE** CONFIGURATION CHANGE / REBOOT GATE	**SOURCES** [9], [10]

Goal Add kernel protections one at a time while preserving driver, peripheral, game, and anti-cheat compatibility.

BEFORE YOU START

- Recovery and acceptance tests passed.
- Inventory required drivers, peripherals, virtualization tools, games, and anti-cheat software.

DO THIS IN ORDER

1. Open Windows Security > Device security > Core isolation.

2. Verify or enable the Microsoft vulnerable-driver blocklist first. Restart only if Windows requests it and complete the full gate.

3. Separately enable Memory integrity only after the first change passes.

4. Restart immediately after the Memory integrity change; do not stack another change.

COMMANDS: None. Use the supported interface named above.

RESTART NOW?
YES after enabling Memory integrity and whenever Windows requests it for the blocklist. Complete the REBOOT GATE.

VERIFY BEFORE CONTINUING

1. Sign in normally with no recovery prompt, crash, missing device, or failed required driver.

2. Memory integrity remains On and runtime data shows VBS running with service value 2 present.

3. Run all affected Step 05 workflows and performance limits.

VERIFICATION COMMANDS

```
$dg = Get-CimInstance `
-Namespace root\Microsoft\Windows\DeviceGuard `
-ClassName Win32_DeviceGuard
$dg | Select-Object VirtualizationBasedSecurityStatus,`
SecurityServicesConfigured,SecurityServicesRunning
```

PASS LOOKS LIKE
The blocklist is on; Memory integrity is effective after reboot; all required workflows and limits pass.

IF IT DOES NOT PASS
HOLD after an incompatible driver, boot problem, hardware error, or measured regression.

ROLLBACK / RECOVERY
Turn off only Memory integrity through Windows Security, restart, and update or replace the exact incompatible driver. Use the proved WinRE path if Windows cannot boot.

RECORD ONLY
Record old/new UI state, restart, runtime summary, and workflow PASS. Do not copy driver paths or event messages publicly.

Independent informational aid | CC BY-NC-ND 4.0 controlled-author terms in LICENSE.md | Do not record secrets

Step 21 - Deploy Attack Surface Reduction rules one at a time

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE F. Staged hardening **CONTROLS** DEF-05, OPS-02	**PRIORITY** P2	**RUN AS** [ADMIN]	**ACTION TYPE** AUDIT-FIRST CONFIGURATION CHANGE	**SOURCES** [12], [13], [33], [35], [45]

Goal Reduce common script, Office, credential, persistence, ransomware, and vulnerable-driver abuse without importing an untested rule bundle.

BEFORE YOU START

- Defender is active and healthy.
- Exceptions were reviewed and required workflows are ready.
- Choose exactly one full GUID from the current Microsoft reference and the ASR candidate appendix.

DO THIS IN ORDER

1. Inventory existing full GUID/action pairs.
2. If the selected rule is not already controlled elsewhere, add only that rule in AuditMode.
3. Complete every applicable workflow and review provider/time-scoped events.
4. When audit results are understood, change only that same rule to Enabled.
5. Repeat the loop for a second rule only after the first rule passes an observation cycle.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
$p = Get-MpPreference
$ids = @($p.AttackSurfaceReductionRules_Ids)
$acts = @($p.AttackSurfaceReductionRules_Actions)
for ($i = 0; $i -lt $ids.Count; $i++) {
[pscustomobject]@{RuleId=[string]$ids[$i];Action=$acts[$i]}
}
$RuleId = 'PASTE-FULL-GUID-FROM-ASR-CANDIDATE-APPENDIX'
Add-MpPreference -AttackSurfaceReductionRules_Ids $RuleId `
-AttackSurfaceReductionRules_Actions AuditMode
Add-MpPreference -AttackSurfaceReductionRules_Ids $RuleId `
-AttackSurfaceReductionRules_Actions Enabled
```

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. The exact full GUID and action are visible.
2. The audit cycle completed, the intended enforced action remains effective, and required workflows pass.
3. Any exception is limited to the exact affected rule and resource.

PASS LOOKS LIKE
Each selected rule was individually audited, enforced, and tested.

IF IT DOES NOT PASS
Return only the affected rule to AuditMode and HOLD while investigating an event or workflow failure.

ROLLBACK / RECOVERY
Run the same Add-MpPreference command for the affected GUID with action AuditMode. Never add a broad exclusion to hide an unexplained block.

RECORD ONLY
Record rule name, full GUID, action, dates, and sanitized result. Event messages and paths remain restricted.

Step 22 - Stage Controlled Folder Access

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE F. Staged hardening **CONTROLS** DEF-06, OPS-02, PERF-02	**PRIORITY** P2	**RUN AS** [ADMIN]	**ACTION TYPE** AUDIT-FIRST CONFIGURATION CHANGE	**SOURCES** [14], [33], [36], [46]

Goal Protect important folders from unauthorized writes without pre-allowing broad folders, launchers, or unknown applications.

BEFORE YOU START

- Defender is active and healthy.
- Required save, open, export, sync, update, screenshot, game-save, creative, and accessibility workflows are defined.

DO THIS IN ORDER

1. Capture the prior mode, then switch to AuditMode.
2. Record the test start time and run every representative writer workflow.
3. Review only CFA events from that time.
4. When every writer is understood, switch to Enabled and repeat the workflows.
5. Allow only an exact verified executable when evidence proves a need.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
$priorCfa = (Get-MpPreference).EnableControlledFolderAccess
Set-MpPreference -EnableControlledFolderAccess AuditMode
$start = Get-Date
Set-MpPreference -EnableControlledFolderAccess Enabled
```

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. The intended mode remains effective.
2. Required writes pass and CFA event 1123/1124 review identifies no unexplained required writer.

VERIFICATION COMMANDS

```
$f = @{
LogName='Microsoft-Windows-Windows Defender/Operational'
Id=1123,1124
StartTime=$start
}
Get-WinEvent -FilterHashtable $f -ErrorAction SilentlyContinue |
Select-Object TimeCreated,Id,ProviderName
Get-MpPreference | Select-Object EnableControlledFolderAccess
```

PASS LOOKS LIKE
CFA is intentional, required writes pass, and every allowance is an exact verified executable.

IF IT DOES NOT PASS
Return to AuditMode and HOLD while investigating the exact writer.

ROLLBACK / RECOVERY
Set-MpPreference -EnableControlledFolderAccess AuditMode

RECORD ONLY
Record mode, test set, event count, and PASS/HOLD only. Do not publish paths or event messages.

Step 23 - Stage Microsoft Defender Network Protection

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE F. Staged hardening **CONTROLS** DEF-07, OPS-02, PERF-02	**PRIORITY** P2	**RUN AS** [ADMIN]	**ACTION TYPE** AUDIT-FIRST CONFIGURATION CHANGE	**SOURCES** [15], [33], [34]

Goal Extend reputation blocking to supported non-Edge browsers and nonbrowser processes on Pro without skipping prerequisite or compatibility tests.

BEFORE YOU START

- Windows 11 Pro is confirmed.
- Defender Antivirus is active with real-time, behavior, and cloud protection enabled.
- Required browsers, launchers, games, updaters, and applications are ready for a representative cycle.

DO THIS IN ORDER

1. Set AuditMode and confirm value 2.

2. In a non-Edge browser, visit Microsoft's harmless SmartScreen test-ratings site linked in reference [34].

3. Confirm event 1125 and complete a representative normal-use cycle.

4. Only after audit PASS, set Enabled and confirm value 1.

5. Repeat the harmless test; confirm the connection is blocked and event 1126 appears.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
Set-MpPreference -EnableNetworkProtection AuditMode
Get-MpPreference | Select-Object EnableNetworkProtection
$npStart = Get-Date
Set-MpPreference -EnableNetworkProtection Enabled
```

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. Audit mode produces event 1125 for the harmless test and required workflows pass.

2. Block mode produces event 1126, blocks the harmless test, remains value 1, and required workflows still pass.

VERIFICATION COMMANDS

```
$np = @{
LogName='Microsoft-Windows-Windows Defender/Operational'
Id=1125,1126
StartTime=$npStart
}
Get-WinEvent -FilterHashtable $np `
-ErrorAction SilentlyContinue |
Select-Object TimeCreated,Id,ProviderName
Get-MpPreference | Select-Object EnableNetworkProtection
```

PASS LOOKS LIKE
Network Protection is locally verified in block mode and required workflows pass.

IF IT DOES NOT PASS
Return to AuditMode and HOLD while investigating prerequisites, a false positive, or a required workflow failure.

ROLLBACK / RECOVERY
Set-MpPreference -EnableNetworkProtection AuditMode

RECORD ONLY
Record mode, harmless-test result, event ID/count, and workflow PASS. Do not publish URLs, paths, or messages from events.

Step 24 - Keep Pro logging proportionate; gate optional command-line capture

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE G. Closeout and maintenance **CONTROLS** LOG-01, LOG-02, LOG-03	**PRIORITY** P2	**RUN AS** [ADMIN]	**ACTION TYPE** READ-ONLY / DECISION	**SOURCES** [2], [4], [20], [42], [44]

Goal Collect only events that support a decision and keep command-line content off by default on the Pro baseline path.

BEFORE YOU START

- Define who will review a log, why, and for how long before adding collection.
- Raw events and command lines may contain personal data and secrets.

DO THIS IN ORDER

1. Review the current audit categories.

2. Keep command-line argument capture Off by default because arguments are stored in plaintext.

3. Only for a defined investigative need, use Appendix E to enable process-creation auditing and command-line content one setting at a time.

4. When querying events, always specify log, provider, event ID, and a deliberate start time.

5. Protect and time-limit raw Security events; rotate any real secret that is accidentally logged.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
auditpol.exe /get /category:*
```

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. Audit scope, review owner, retention, access, and deletion are documented.

2. No plaintext command-line collection exists without a clear accepted need.

PASS LOOKS LIKE
Logging is proportionate and privacy-controlled; optional command-line capture is either Off or explicitly justified, tested, and restricted.

IF IT DOES NOT PASS
HOLD additional logging when no review use case exists or sensitive content cannot be protected.

ROLLBACK / RECOVERY
Return only the exact latest audit setting to its recorded prior state; do not clear logs to hide an error.

RECORD ONLY
Record audit categories and handling decisions only. Raw log content stays restricted.

Step 25 - Run final acceptance and schedule reassessment

PHASE	PRIORITY	RUN AS	ACTION TYPE	SOURCES
PHASE G. Closeout and maintenance **CONTROLS** OPS-01, OPS-02, OPS-03, OPS-04, PERF-01, PERF-02	**PRIORITY** P1	**RUN AS** [USER]	**ACTION TYPE** ACTIVE ACCEPTANCE TEST / RECORD	**SOURCES** [1], [2], [3], [4]

Goal Close only controls actually proved, leave unknowns visible, and make the baseline maintainable.

BEFORE YOU START

- All earlier steps are PASS, HOLD, EXCEPTION, or documented N/A.
- No unexplained stacked change remains.

DO THIS IN ORDER

1. Run the complete Step 05 workflow and performance suite.
2. Open Reliability Monitor and review the period covering the changes.
3. Close each control only with the result actually supported.
4. Record every exception with scope, owner, reason, compensating measure, approval date, and next review.
5. Set review triggers for major Windows, firmware, driver, security-tool, network, remote-access, incident, or recovery changes.

COPY / PASTE COMMANDS

Run only after reading the numbered actions. State-changing lines are conditional.

```
perfmon.exe /rel
```

RESTART NOW?
NO.

VERIFY BEFORE CONTINUING

1. Every retained control has a result, date, owner, and review trigger/date.
2. Required workflows and limits pass with no new unexplained reliability failure.
3. Public materials contain no sensitive evidence.

PASS LOOKS LIKE
The edition-specific baseline has a complete, dated, reviewable outcome.

IF IT DOES NOT PASS
Leave the affected item HOLD. Do not call the overall baseline complete while instability or unexplained results remain.

ROLLBACK / RECOVERY
Reverse only the latest documented reversible change tied to the failure, then repeat its focused and representative tests.

RECORD ONLY
Record final results and next-review dates. Restricted evidence remains outside the public repository.

Appendix A - Reboot gate

Use this gate after every firmware, Secure Boot, SMB1, Memory integrity, BitLocker system-check, or other restart-dependent change. Do not start the next material change until every applicable item passes.

1. SIGN IN	Normal sign-in succeeds without an unexpected recovery prompt.
2. STABILITY	No new crash, repeated hardware error, missing device, or unexplained restart appears.
3. FOCUSED CHECK	The one feature just changed is effective in Windows runtime state.
4. WORKFLOWS	Every affected Step 05 test passes.
5. LIMITS	Applicable reliability and performance limits remain acceptable.
6. DECISION	Record PASS and observe normal use, or HOLD and reverse only the latest change.

If Windows cannot boot Use the already proved Windows RE path. Restore only the latest documented reversible setting. Do not clear TPM, CMOS, or Secure Boot keys and do not stack another change.

Appendix B - Pro control matrix

The matrix is a reference and traceability appendix. Use the numbered procedure above to do the work.

ID / PRIORITY	PRO OUTCOME	PROCEDURE STEP	SOURCES
GOV-01 P0	Authority is confirmed; managed devices are referred to the authorized administrator.	**01**	**[1], [2]**
GOV-02 P0	Evidence is minimal, redacted, access-controlled, and stored outside public repositories when sensitive.	**02**	**[1], [2], [4]**
REC-01 P0	A representative restore succeeds from a current copy isolated from routine write access.	**03**	**[1], [2], [5]**
REC-02 P0	Encryption state is known and its recovery method is accessible without recording the secret.	**04, 12**	**[7]**
REC-03 P0	Windows RE and an independent administrator sign-in are tested.	**04, 10**	**[2], [30]**
PLT-01 P1	Windows is supported, security updates are current, and any compatibility hold is documented.	**01, 06, 07**	**[6]**
PLT-02 P0	Windows reports UEFI mode and Secure Boot enabled; recovery readiness passes first.	**06, 09**	**[8]**
PLT-03 P0	TPM health fields pass without clearing, reprovisioning, or exposing key material.	**06, 09**	**[21]**
PLT-04 P2	Pro: separately inventory CPU virtualization, IOMMU, Kernel DMA Protection, VBS, and Memory integrity.	**06, 09, 20**	**[9], [22]**
PLT-05 P1	Exact-model applicability, prerequisites, recovery, power, and post-update checks are documented.	**06, 08**	**[2], [6]**
PLT-06 P1	Pro: use the supported BitLocker wizard, system-check restart, full status verification, and independent recovery.	**12**	**[7]**
ID-01 P1	Routine work uses a standard account and administration requires deliberate elevation.	**04, 10**	**[2], [18]**
ID-02 P1	Strong authentication and two independent recovery methods are configured and tested.	**11**	**[1], [23]**
ID-03 P1	UAC is default-or-higher and elevation is a deliberate, visible action.	**10**	**[19]**
DEF-01 P1	The intended antimalware provider is active, healthy, and current.	**07, 13**	**[11], [25]**
DEF-02 P1	Runtime protections and tamper resistance are enabled or an authorized exception exists.	**13**	**[24], [25]**
DEF-03 P1	Cloud protection is enabled and sample handling is an intentional privacy choice.	**13**	**[25]**
DEF-04 P1	PUA protection is in Block mode and retained exceptions have a verified need and source.	**13**	**[26]**

ID / PRIORITY	PRO OUTCOME	PROCEDURE STEP	SOURCES
DEF-05 P2	Applicable ASR rules have full GUIDs, explicit modes, owners, tests, and narrow exceptions.	**21**	**[12], [13]**
DEF-06 P2	CFA is intentional and required writes pass without broad allowances.	**22**	**[14]**
DEF-07 P2	Pro: audit Network Protection, run Microsoft's harmless test, then enforce and repeat the test.	**23**	**[15]**
APP-01 P1	Applicable reputation controls are enabled and exceptions are specific and verified.	**14**	**[27]**
APP-02 P2	Driver blocking is enabled; VBS and HVCI are intentional and pass compatibility tests.	**20**	**[9], [10]**
NET-01 P1	All profiles are enabled and custom inbound rules are narrowly scoped and justified.	**15**	**[16]**
NET-02 P1	Pro: leave RDP hosting off unless required; if enabled, require NLA and trusted-network firewall scope.	**16**	**[2], [28]**
NET-03 P1	SMB1 and insecure guest access are absent; required shares are authenticated and scoped.	**17**	**[17]**
NET-04 P2	Resolver and failover paths are documented and pass representative tests.	**18**	**[29]**
LOG-01 P2	Audit scope, retention, access, and deletion rights are proportionate and documented.	**24**	**[2], [4]**
LOG-02 P2	Pro: command-line capture is optional, privacy-gated, and off by default.	**24**	**[4], [20]**
LOG-03 P2	Event evidence is provider-scoped, time-scoped, minimal, and tied to a decision.	**24**	**[4], [20]**
OPS-01 P1	Every exception is narrow, owned, tested, and scheduled for review or removal.	**19, 25**	**[1], [2]**
OPS-02 P1	Each material change is isolated, reversible, tested, and observed.	**02, 05, 08, 20, 21, 22, 23, 25**	**[1], [2]**
OPS-03 P0	Baseline work stops during suspected compromise or instability and follows an authorized path.	**01, 25**	**[3]**
OPS-04 P3	Every applicable control has an owner and review trigger or date.	**25**	**[1]**
PERF-01 P2	Applicable performance and reliability limits are defined and tested consistently.	**05, 20, 25**	**[1], [2]**
PERF-02 P1	Required workflows pass after each material change without disabling broad protections.	**05, 20, 22, 23, 25**	**[1], [2]**

Appendix C - ASR candidate reference

This list identifies candidates; it does not prescribe a bulk preset. Use current Microsoft applicability and deploy one full GUID at a time through Step 21.

FULL GUID	MICROSOFT RULE NAME	APPLICABILITY NOTE
`56a863a9-875e-4185-98a7-b882c64b5ce5`	Block abuse of exploited vulnerable signed drivers	Evaluate broadly. This prevents an application from writing a vulnerable signed driver; it does not stop an already-present vulnerable driver from loading.
`d3e037e1-3eb8-44c8-a917-57927947596d`	Block JavaScript or VBScript from launching downloaded executable content	Evaluate when script-based installers or administration workflows have been inventoried.
`e6db77e5-3df2-4cf1-b95a-636979351e5b`	Block persistence through WMI event subscription	Evaluate after inventorying legitimate management or monitoring tools.
`c1db55ab-c21a-4637-bb3f-a12568109d35`	Use advanced protection against ransomware	Evaluate after storage, backup, sync, and application workflows are defined.
`d4f940ab-401b-4efc-aadc-ad5f3c50688a`	Block Office applications from creating child processes	Applicable when Microsoft Office desktop applications are installed and required add-ins or automation have been tested.
`3b576869-a4ec-4529-8536-b80a7769e899`	Block Office applications from creating executable content	Applicable when Microsoft Office desktop applications are installed.
`75668c1f-73b5-4cf0-bb93-3ecf5cb7cc84`	Block Office applications from injecting code	Applicable when Microsoft Office desktop applications are installed and compatibility is understood.
`92e97fa1-2edf-4476-bdd6-9dd0b4dddc7b`	Block Win32 API calls from Office macros	Applicable only after legitimate macro and automation needs are inventoried.
`be9ba2d9-53ea-4cdc-84e5-9b1eeee46550`	Block executable content from email client and webmail	Evaluate after required mail-client and attachment workflows are tested.

Appendix D - Optional Pro Remote Desktop host

Default decision: OFF	Skip this appendix when incoming Remote Desktop is not required. Never forward TCP 3389 directly from the Internet; use a trusted VPN for outside-network access.

Preconditions: trusted Private network; strong unique password; NLA-capable client; intended account; documented need; no unknown management policy.

Do this in order

1. Settings > System > Remote Desktop > On.
2. Keep Require devices to use Network Level Authentication enabled.
3. Under Remote Desktop users, add only the intended account; avoid routine remote administrator use.
4. In Windows Firewall with Advanced Security, keep Remote Desktop inbound rules off on Public.
5. Limit the allowed remote addresses to Local subnet or a narrower trusted range.
6. From a second trusted device, test the intended account and confirm no other account can sign in.

```
$path = 'HKLM:\SYSTEM\CurrentControlSet\Control\Terminal Server'
Get-ItemPropertyValue -Path $path -Name fDenyTSConnections
$nlaPath = "$path\WinStations\RDP-Tcp"
Get-ItemPropertyValue -Path $nlaPath -Name UserAuthentication
Get-NetTCPConnection -LocalPort 3389 -State Listen `
-ErrorAction SilentlyContinue
```

PASS	fDenyTSConnections is 0, UserAuthentication is 1, only intended accounts connect, rules exclude Public, remote scope is LocalSubnet or narrower, and no direct Internet exposure exists.
Rollback	Settings > System > Remote Desktop > Off. Verify fDenyTSConnections is 1 and no TCP 3389 listener remains.

Appendix E - Optional Pro Event 4688 command-line content

Default decision: OFF	Command-line arguments are stored in plaintext and can contain passwords, tokens, private paths, and personal data. Enable this only for a defined investigative use with restricted access, retention, and review.

Do this in order only after accepting the privacy cost

1. Open secpol.msc > Advanced Audit Policy Configuration > Detailed Tracking > Audit Process Creation and enable Success.

2. Open gpedit.msc > Computer Configuration > Administrative Templates > System > Audit Process Creation.

3. Set Include command line in process creation events to Enabled.

4. Apply policy, generate the harmless Notepad test below, and inspect only the recent matching Security event.

5. Define who can read the Security log, how long it is kept, and when this optional setting will be reviewed.

```
gpupdate.exe /target:computer /force
$start = Get-Date
$notepad = Join-Path $env:WINDIR 'System32\notepad.exe'
Start-Process $notepad -ArgumentList 'SBC-4688-test.txt'
$f = @{
LogName='Security'
ProviderName='Microsoft-Windows-Security-Auditing'
Id=4688
StartTime=$start
}
Get-WinEvent -FilterHashtable $f -MaxEvents 50 |
Select-Object -First 1 TimeCreated,Id,ProviderName
```

PASS	A new provider-scoped 4688 event appears for the harmless test, access and retention are controlled, and the owner accepts the privacy cost.
Rollback	Return both policy settings to their recorded prior states and run gpupdate again. Do not clear the Security log. If a real secret was logged, treat it as exposed and rotate it.

Appendix F - IEEE-style references

Source review cut-off: 29 July 2026. Reference numbers remain stable within version 1.0.0. Product behavior, licensing, interfaces, and recommendations can change.

IEEE-STYLE REFERENCE	USE
[1] National Institute of Standards and Technology, "The NIST Cybersecurity Framework (CSF) 2.0", NIST CSWP 29, Feb. 2024. [Online]. Available: https://doi.org/10.6028/NIST.CSWP.29. Accessed: Jul. 29, 2026.	Govern, identify, protect, detect, respond, and recover outcomes.
[2] National Institute of Standards and Technology, "Security and Privacy Controls for Information Systems and Organizations", NIST SP 800-53 Rev. 5, Sept. 2020 (includes updates as of Dec. 10, 2020). [Online]. Available: https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final. Accessed: Jul. 29, 2026.	Least privilege, configuration, logging, contingency planning, and recovery controls.
[3] National Institute of Standards and Technology, "Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile", NIST SP 800-61 Rev. 3, Apr. 2025. [Online]. Available: https://csrc.nist.gov/pubs/sp/800/61/r3/final. Accessed: Jul. 29, 2026.	Incident-response recommendations and CSF 2.0 integration.
[4] National Institute of Standards and Technology, "Guide to Computer Security Log Management", NIST SP 800-92, Sept. 2006. [Online]. Available: https://csrc.nist.gov/pubs/sp/800/92/final. Accessed: Jul. 29, 2026.	Security-log planning, handling, retention, and operations.
[5] Cybersecurity and Infrastructure Security Agency, "#StopRansomware Guide", rev. Oct. 19, 2023. [Online]. Available: https://www.cisa.gov/resources-tools/resources/stopransomware-guide. Accessed: Jul. 29, 2026.	Backups, recovery testing, access control, and preparation.
[6] Microsoft, "Windows 11 release information". [Online]. Available: https://learn.microsoft.com/en-us/windows/release-health/windows11-release-information. Accessed: Jul. 29, 2026.	Current servicing and release-health information.
[7] Microsoft, "BitLocker Overview". [Online]. Available: https://learn.microsoft.com/en-us/windows/security/operating-system-security/data-protection/bitlocker/. Accessed: Jul. 29, 2026.	Encryption capabilities and recovery considerations.
[8] Microsoft Support, "Windows 11 and Secure Boot". [Online]. Available: https://support.microsoft.com/en-us/windows/security/devicesecurity/windows-11-and-secure-boot. Accessed: Jul. 29, 2026.	Secure Boot purpose, firmware guidance, and supported Windows behavior.
[9] Microsoft, "Enable memory integrity". [Online]. Available: https://learn.microsoft.com/en-us/windows/security/hardware-security/enable-virtualization-based-protection-of-code-integrity. Accessed: Jul. 29, 2026.	Memory Integrity and VBS enablement, compatibility, and rollback.
[10] Microsoft, "Microsoft recommended driver block rules". [Online]. Available: https://learn.microsoft.com/en-us/windows/security/application-security/application-control/app-control-for-business/design/microsoft-recommended-driver-block-rules. Accessed: Jul. 29, 2026.	Vulnerable-driver blocklist behavior and compatibility.
[11] Microsoft, "Microsoft Defender Antivirus security intelligence and product updates and support". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/microsoft-defender-antivirus-updates. Accessed: Jul. 29, 2026.	Platform, engine, and security-intelligence servicing.
[12] Microsoft, "ASR rules reference". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference. Accessed: Jul. 29, 2026.	Full ASR rule GUIDs, modes, prerequisites, and compatibility.
[13] Microsoft, "Plan your attack surface reduction (ASR) rules deployment". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-deployment-plan. Accessed: Jul. 29, 2026.	Assessment, Audit mode, reporting, and staged enforcement.
[14] Microsoft, "Controlled folder access (CFA) overview". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/controlled-folder-access-overview. Accessed: Jul. 29, 2026.	Scope, modes, dependencies, and monitoring.
[15] Microsoft, "Use network protection to help prevent connections to malicious or suspicious sites". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/network-protection. Accessed: Jul. 29, 2026.	Current prerequisites, modes, and safe evaluation.
[16] Microsoft, "Windows Firewall Rules". [Online]. Available: https://learn.microsoft.com/en-us/windows/security/operating-system-security/network-security/windows-firewall/rules. Accessed: Jul. 29, 2026.	Narrow rule scope, precedence, and firewall design.

IEEE-STYLE REFERENCE	USE
[17] Microsoft, "SMB security hardening in Windows Server and Windows Client". [Online]. Available: https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-security-hardening. Accessed: Jul. 29, 2026.	Signing, guest access, SMB1, and current behavior.
[18] Microsoft, "Local accounts". [Online]. Available: https://learn.microsoft.com/en-us/windows/security/identity-protection/access-control/local-accounts. Accessed: Jul. 29, 2026.	Daily-use and administrative-account separation.
[19] Microsoft Support, "User Account Control settings". [Online]. Available: https://support.microsoft.com/en-us/windows/security/user-account-control-settings. Accessed: Jul. 29, 2026.	Supported UAC levels and prompt behavior.
[20] Microsoft, "Command line process auditing". [Online]. Available: https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/component-updates/command-line-process-auditing. Accessed: Jul. 29, 2026.	Event 4688 configuration and plaintext-secret warning.
[21] Microsoft, "TPM recommendations". [Online]. Available: https://learn.microsoft.com/en-us/windows/security/hardware-security/tpm/tpm-recommendations. Accessed: Jul. 29, 2026.	TPM capabilities, Windows dependencies, and recommendations.
[22] Microsoft, "Kernel DMA Protection". [Online]. Available: https://learn.microsoft.com/en-us/windows/security/hardware-security/kernel-dma-protection-for-thunderbolt. Accessed: Jul. 29, 2026.	Hardware, firmware, driver, and edition dependencies.
[23] Microsoft, "Passwordless sign-in". [Online]. Available: https://learn.microsoft.com/en-us/windows/security/book/identity-protection-passwordless-sign-in. Accessed: Jul. 29, 2026.	Windows Hello, passkeys, FIDO2, and phishing-resistant sign-in.
[24] Microsoft, "Protect security settings with tamper protection". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/prevent-changes-to-security-settings-with-tamper-protection. Accessed: Jul. 29, 2026.	Tamper-protection purpose, behavior, and management ownership.
[25] Microsoft, "Configure behavioral, heuristic, and real-time protection". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/configure-protection-features-microsoft-defender-antivirus. Accessed: Jul. 29, 2026.	Real-time, behavior, IOAV, cloud, and related protection features.
[26] Microsoft, "Detect and block potentially unwanted applications". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/detect-block-potentially-unwanted-apps-microsoft-defender-antivirus. Accessed: Jul. 29, 2026.	PUA applicability, modes, configuration, and review.
[27] Microsoft Support, "App & browser control in the Windows Security App". [Online]. Available: https://support.microsoft.com/en-us/windows/security/windows-security/app-browser-control-in-the-windows-security-app. Accessed: Jul. 29, 2026.	Reputation-based protection and Smart App Control availability.
[28] Microsoft, "Enable Remote Desktop on your PC". [Online]. Available: https://learn.microsoft.com/en-us/windows-server/remote/remote-desktop-services/remotepc/remote-desktop-allow-access. Accessed: Jul. 29, 2026.	Remote Desktop exposure, trusted-network scope, authentication, and editions.
[29] Microsoft, "DNS Queries and Lookups in Windows and Windows Server". [Online]. Available: https://learn.microsoft.com/en-us/windows-server/networking/dns/queries-lookups. Accessed: Jul. 29, 2026.	Windows DNS client behavior and resolver redundancy.
[30] Microsoft, "Push-button reset frequently-asked questions (FAQ)". [Online]. Available: https://learn.microsoft.com/en-us/windows-hardware/manufacture/desktop/pbr-faq?view=windows-11. Accessed: Jul. 29, 2026.	Windows Recovery Environment and recovery-tool requirements.
[31] Microsoft Support, "Device Encryption in Windows". [Online]. Available: https://support.microsoft.com/en-us/windows/security/encryption/device-encryption-in-windows. Accessed: Jul. 29, 2026.	Home availability, prerequisites, recovery-account behavior, and supported UI.
[32] Microsoft Support, "BitLocker Drive Encryption". [Online]. Available: https://support.microsoft.com/en-us/windows/security/encryption/bitlocker-drive-encryption. Accessed: Jul. 29, 2026.	Pro-and-higher availability and the supported BitLocker management UI.
[33] Microsoft, "Set-MpPreference". [Online]. Available: https://learn.microsoft.com/en-us/powershell/module/defender/set-mppreference. Accessed: Jul. 29, 2026.	Elevated Defender configuration syntax and supported values.

IEEE-STYLE REFERENCE	USE
[34] Microsoft, "Evaluate network protection". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/evaluate-network-protection. Accessed: Jul. 29, 2026.	Official harmless test, audit and block workflow, and events 1125 and 1126.
[35] Microsoft, "Attack surface reduction events in Windows Event Viewer". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-windows-events. Accessed: Jul. 29, 2026.	Provider-specific ASR, CFA, and Network Protection event identifiers.
[36] Microsoft, "Monitor controlled folder access activity". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/controlled-folder-access-monitor. Accessed: Jul. 29, 2026.	Controlled Folder Access audit and block events plus evaluation guidance.
[37] Microsoft, "Set-NetFirewallProfile". [Online]. Available: https://learn.microsoft.com/en-us/powershell/module/netsecurity/set-netfirewallprofile. Accessed: Jul. 29, 2026.	Supported Windows Firewall profile configuration syntax.
[38] Microsoft, "Detect, enable, and disable SMBv1, SMBv2, and SMBv3 in Windows". [Online]. Available: https://learn.microsoft.com/en-us/windows-server/storage/file-server/troubleshoot/detect-enable-and-disable-smbv1-v2-v3. Accessed: Jul. 29, 2026.	SMB1 feature detection, removal, and restart behavior.
[39] Microsoft, "Get-BitLockerVolume". [Online]. Available: https://learn.microsoft.com/en-us/powershell/module/bitlocker/get-bitlockervolume. Accessed: Jul. 29, 2026.	BitLocker volume, protection, encryption, and protector status fields.
[40] Microsoft, "BitLocker operations guide". [Online]. Available: https://learn.microsoft.com/en-us/windows/security/operating-system-security/data-protection/bitlocker/operations-guide. Accessed: Jul. 29, 2026.	Supported enablement, system-check, recovery, and operating procedures.
[41] National Institute of Standards and Technology, "Guide to Storage Encryption Technologies for End User Devices", NIST SP 800-111, Nov. 2007. [Online]. Available: https://csrc.nist.gov/pubs/sp/800/111/final. Accessed: Jul. 29, 2026.	Technology-neutral endpoint storage-encryption and recovery considerations.
[42] Microsoft, "auditpol set". [Online]. Available: https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/auditpol-set. Accessed: Jul. 29, 2026.	Supported audit-policy subcategory configuration syntax.
[43] National Institute of Standards and Technology, "Guide to Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security", NIST SP 800-46 Rev. 2, July 2016. [Online]. Available: https://csrc.nist.gov/pubs/sp/800/46/r2/final. Accessed: Jul. 29, 2026.	Remote-access threat, authentication, and lifecycle considerations.
[44] Microsoft, "Policy CSP - ADMX_AuditSettings". [Online]. Available: https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-admx-auditsettings. Accessed: Jul. 29, 2026.	Edition applicability and plaintext privacy warning for process command-line auditing.
[45] Microsoft, "Attack surface reduction (ASR) rules overview". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-overview. Accessed: Jul. 29, 2026.	Any-edition availability with Microsoft Defender Antivirus, local PowerShell configuration, modes, and audit-first deployment.
[46] Microsoft, "Configure controlled folder access (CFA)". [Online]. Available: https://learn.microsoft.com/en-us/defender-endpoint/controlled-folder-access-configure. Accessed: Jul. 29, 2026.	Windows 10-or-later applicability, elevated PowerShell configuration, modes, and Windows Security workflow.
[47] Microsoft, "How to enable insecure guest logons in SMB2 and SMB3". [Online]. Available: https://learn.microsoft.com/en-us/windows-server/storage/file-server/enable-insecure-guest-logons-smb2-and-smb3. Accessed: Jul. 29, 2026.	Windows 11 applicability, administrator requirement, insecure-guest risk, defaults, and PowerShell configuration.
[48] Microsoft, "manage-bde". [Online]. Available: https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/manage-bde. Accessed: Jul. 29, 2026.	Windows 11 command-line encryption-status support for all drives, including unprotected drives.